

# Challenges in the Adoption of Passkeys – Technical and Societal Aspects

Ricardo Straub

**Abstract:** The adoption of passkeys, an alternative to traditional password-based authentication, promises enhanced security and a user-friendly experience. However, their widespread adoption faces several technical and societal challenges. While passkeys address vulnerabilities such as phishing and brute force attacks through public key cryptography, barriers including user misconceptions, technical integration difficulties, and limited cross-platform support hinder their adoption. Additionally, the lack of awareness and concerns about the security of passkeys contribute to resistance, particularly among non-technical users and organizations with outdated systems. This paper explores the advantages and challenges of passkey adoption, discussing both the technical and societal aspects influencing their integration into personal and organizational environments.

**Keywords:** Passkeys, Authentication, Public Key Cryptography, FIDO2, Security, Usability, User Adoption, Technical Challenges, Misconceptions, Cross-Platform Support, Identity Management, Regulatory Requirements

## 1 Why Replace Traditional Authentication Methods?

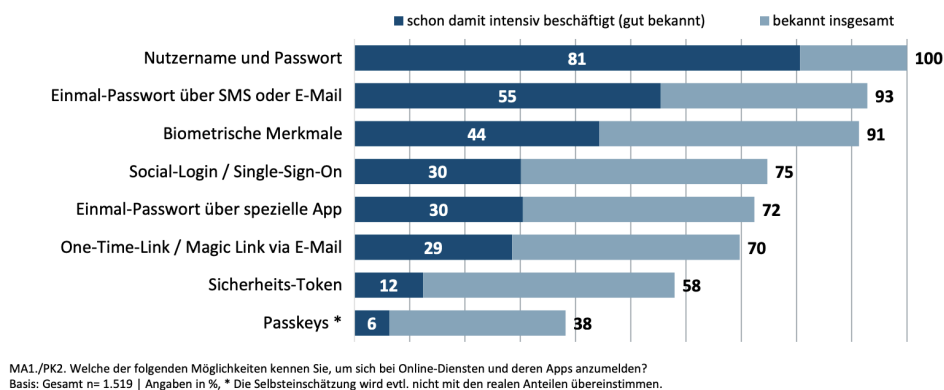


Abb. 1: Prominence of different authentication methods  
[8]

The maintenance of traditional text-based passwords places a significant burden on IT support teams, primarily due to frequent password reset requests triggered by users forgetting their credentials or by regulatory compliance requirements. Passwords, though a foundational element of cybersecurity for decades, are inherently flawed as a method of user authentication.

Their primary weakness lies in the ease with which they can be compromised. Phishing attacks trick users into entering their credentials on forged login pages, often resulting in account breaches. Moreover, static passwords are frequently exposed in database leaks, where they can be captured by attackers and reused for unauthorized access. During each login session, passwords must be sent to the server for authentication, where they are hashed and stored. However, once an attacker gains access to the hashed version of these passwords, they can exploit them multiple times, gaining unauthorized access to accounts, sometimes across platforms if password reuse is involved. Advancements in computing power have further exacerbated the problem, making it possible to crack even seemingly strong passwords in a matter of hours or minutes through brute force. Additionally, password guessing remains a widespread threat, especially when users practice bad habits such as choosing easily guessable passwords or reusing the same password across multiple sites.

To mitigate some of these risks, supplementary technologies such as two-factor authentication (2FA) have been implemented. While these solutions add another layer of protection by requiring users to verify their identity using a second form of authentication—such as a text message or an authenticator app—they are not immune to modern attack methods. For instance, attackers may intercept SMS messages or bypass traditional 2FA methods using social engineering tactics. Furthermore, the demand for users to create and remember strong, unique passwords for each service has become an increasingly unrealistic expectation. The average user struggles with managing multiple complex passwords, leading to frustration and, often, the adoption of insecure workarounds, such as writing passwords down or using simple, memorable phrases. This creates a cycle where security is compromised for the sake of convenience.

As the attack surface expands and the sophistication of cyber threats increases, the need for a more secure and user-friendly authentication method becomes more urgent. This is where innovations like passkeys offer promising alternatives that could shift the way we think about authentication. By moving away from passwords, passkeys aim to provide a more secure and user-friendly mean of securing online identities while mitigating the risks that have been associated with traditional password systems.

## **2 What are Passkeys?**

“A passkey is a FIDO authentication credential based on FIDO standards, that allows a user to sign in to apps and websites with the same process that they use to unlock their device (biometrics, PIN, or pattern)” [1].

Passkeys represent a significant advancement in authentication technology, offering a secure, user-friendly alternative to traditional methods like passwords. They are based on public key cryptography and the FIDO2 standards, which were developed by the FIDO Alliance—a consortium of industry leaders aiming to minimize dependency on vulnerable password-based systems [7, 2].

The core concept of passkeys lies in the use of a public-private key pair for authentication. When a user registers with a service, the WebAuthn API generates a unique key pair directly on the client device. The private key is stored securely on the device or synchronized to the cloud via platforms like Apple iCloud Keychain, Google Password Manager, or Microsoft Authenticator, depending on the ecosystem. In contrast, the public key is sent to and stored on the service provider's server. During authentication, the client device uses the private key to cryptographically sign a challenge provided by the server, which verifies the signature using the corresponding public key. This process ensures secure, passwordless authentication without exposing sensitive data [5, 6].

### Creating a passkey

**Step 1 (Abb.2):** The user initiates the registration process by clicking the register button, prompting the server to issue a challenge nonce.

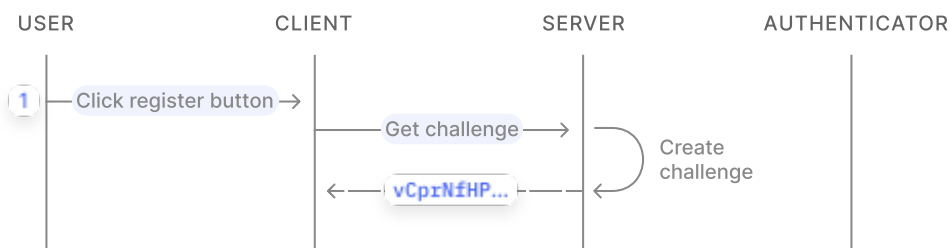


Abb. 2: Step 1  
[6]

**Step 2 (Abb.3):** Upon receiving the challenge, the client calls the WebAuthn API, which may require the user to complete an optional verification step using biometrics or a PIN. This triggers the authenticator to generate a public-private key pair [5, 6]. The private key is securely stored either locally on the device or in the cloud, depending on the implementation [5, 7, 6]. The private key is used to sign the challenge nonce, ensuring its authenticity. The authenticator then returns the public key, a credential ID, as well as the signed challenge nonce to the client [5, 6].

**Step 3 (Abb.4):** These elements are forwarded to the server, which associates the public key and the credential ID with the newly created user. Finally, the server verifies the signed challenge nonce using the provided public key to confirm the authenticity of the registration. Once the verification is successful, the registration process is complete [6].

### Authenticating with a passkey

**Step 1 (Abb.5):** The user initiates a sign-in process with a passkey, prompting the server to generate and issue a challenge nonce to the client [5, 6].

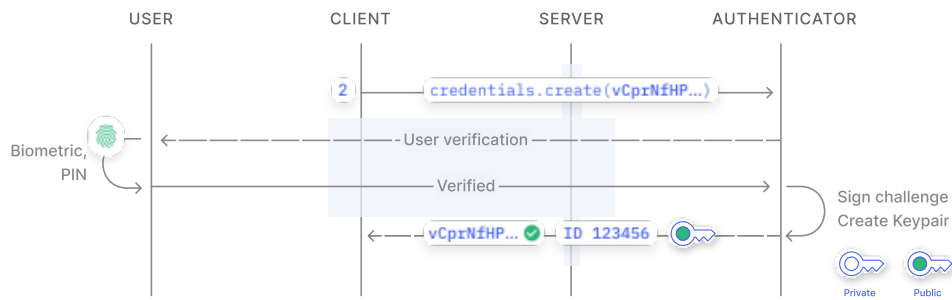


Abb. 3: Step 2  
[6]

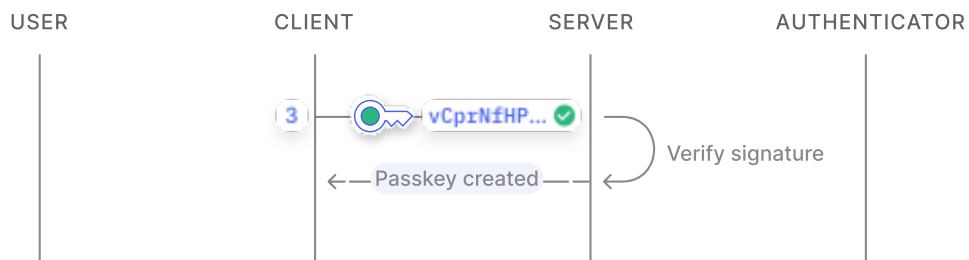


Abb. 4: Step 3  
[6]

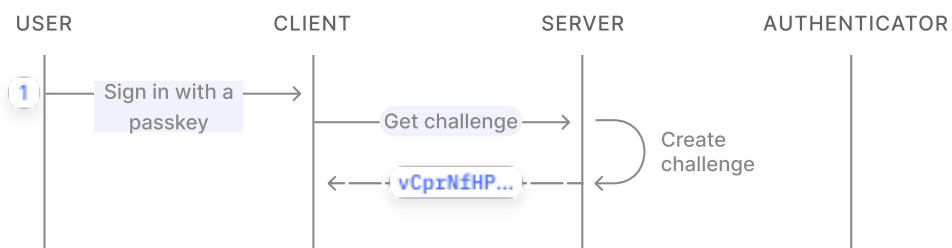


Abb. 5: Step 1  
[6]

**Step 2 (Abb.6):** Upon receiving the challenge, the client calls the WebAuthn API, which may require the user to complete an optional verification step using biometrics or a PIN. The authenticator then signs the challenge nonce using the user's private key. The signed challenge, along with the user's credential ID and username, is returned to the client [5, 6].

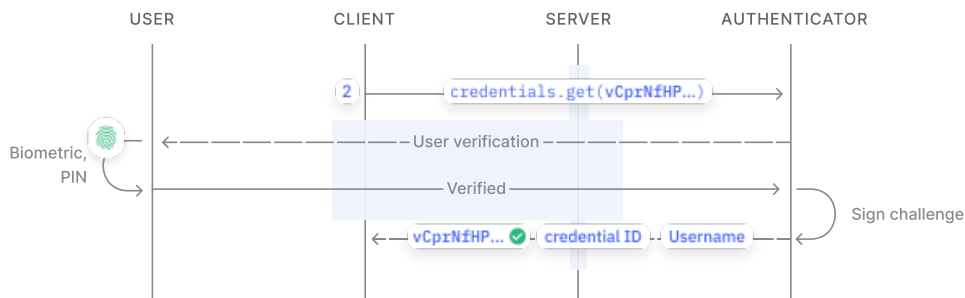


Abb. 6: Step 2  
[6]

**Step 3 (Abb.7):** The client forwards these credentials to the server. The server checks whether the provided credential ID and username correspond to a registered user. If a match is found, the server verifies the signed challenge using the public key of the user [5, 6]. Once the signature is successfully verified, the server confirms the user's identity and issues an authorization token, granting access to the requested service [6].

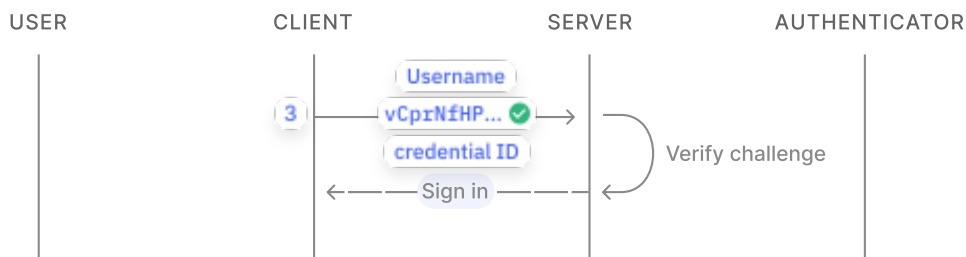


Abb. 7: Step 3  
[6]

### 3 Advantages of Passkeys

Passkeys offer a secure and user-friendly alternative to traditional password-based authentication by addressing multiple vulnerabilities and improving the user experience. By leveraging asymmetric encryption, passkeys eliminate the risk of phishing and man-in-the-middle attacks, as private keys are never exposed or transmitted over the network [7, 5]. Unlike

passwords, passkeys never involve sending a static secret to the server. Each login session generates a unique cryptographic challenge that is signed with the private key, ensuring that even if this signed challenge is intercepted, it cannot be reused for another session or across different services [5].

The use of public-private key cryptography ensures that public keys, securely stored on the server, are unique to each user account [5, 6]. The private key remains safely stored on the user's device or synchronized through a cloud service, depending on the implementation. Additionally, passkeys are resistant to offline brute-force attacks because no shared secret is ever stored on the server [5].

By incorporating on-device user verification methods such as biometric authentication or device PINs, passkeys enhance both security and usability. This approach not only eliminates the need for users to create and remember passwords but also addresses common security issues like password reuse and weak password choices. Passkeys reduce the workload for IT support teams, as there are no forgotten passwords to reset, and they provide users with a faster and more seamless login process [5].

Through a combination of cryptographic best practices and ease of use, passkeys represent a significant improvement over traditional password-based authentication methods [5]. By mitigating key vulnerabilities and simplifying the user experience, they pave the way for a more secure and efficient approach to authentication.

## **4 Disadvantages of Passkeys**

While passkeys offer significant security benefits, they also come with notable disadvantages that may hinder their usability and resilience in certain scenarios. One major limitation is their dependence on personal devices, which makes accessing accounts from shared or public devices impractical. Since passkeys are tied to specific hardware or cloud-based management systems, users may face challenges when attempting to log in on unfamiliar devices [5].

Account recovery strategies for passkeys also present a significant challenge. Many implementations rely on existing recovery mechanisms, such as SMS or email, which can reduce overall security in high-risk situations [7, 5]. If passwords are used as part of a recovery method, the system becomes vulnerable to downgrade attacks, undermining the core advantages of passkeys [7]. Inconsistent or poorly implemented recovery processes can further confuse users, eroding confidence in the system [5].

Although passkeys are resistant to phishing attacks, they are not immune to all forms of social engineering. Attackers could trick users into re-enrolling a new passkey on a compromised device or platform, thereby gaining unauthorized access. Malware or malicious websites may also target users in passwordless systems, exploiting vulnerabilities unrelated to passkeys themselves [5].

These limitations highlight the importance of robust ecosystem support, clear recovery procedures, and enhanced user education to prevent misuse or exploitation. While passkeys offer a secure alternative to traditional passwords, their practical challenges, particularly in scenarios involving shared devices or account recovery, may limit their widespread adoption and effectiveness [5].

## 5 Challenges in the adoption of Passkeys

### 5.1 Private users

Despite the numerous advantages of passkeys over traditional authentication methods, their adoption is hindered by technical challenges and widespread misconceptions. These barriers significantly slow the transition to passkeys. However, passkeys hold great potential for future adoption as users become more educated about the technology and its benefits [8][Abb.8].

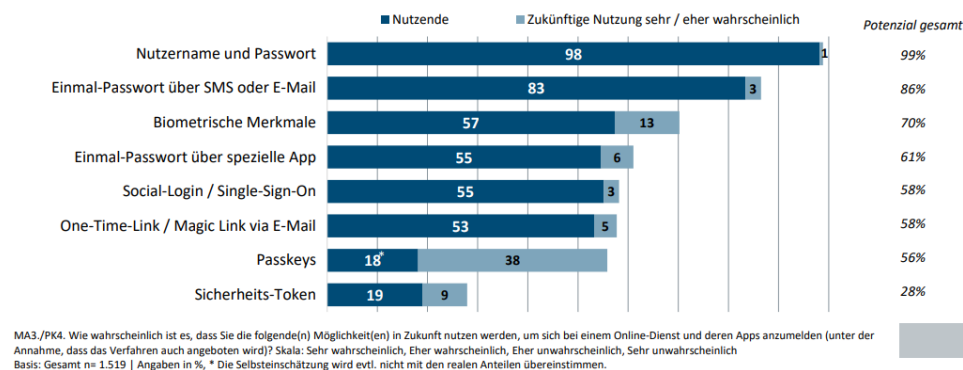


Abb. 8: How likely is a future use of an authentication method [8]

Among the most commonly cited advantages from passkey users is the elimination of the need to remember passwords. Additionally, users highlight the speed and user-friendliness of passkey-based authentication as key benefits. Increased security is another major reason individuals choose to adopt passkeys [8]. These perceived advantages align closely with the factors individuals consider when deciding to replace their existing authentication methods [Abb.9].

### Lack of Awareness and Misconceptions

A major obstacle to the adoption of passkeys is the widespread lack of awareness among users. Most individuals are either unfamiliar with the term “passkey” or have only a vague understanding of what it entails. This knowledge gap is particularly pronounced among

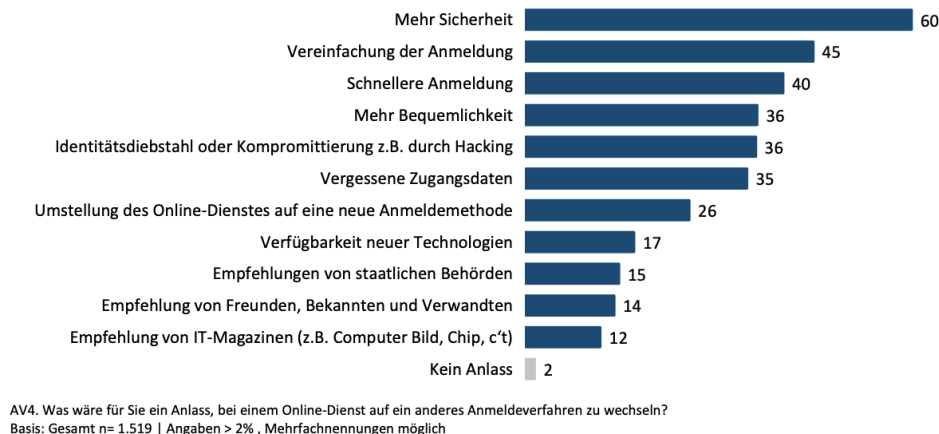


Abb. 9: Reasons cited for changing the authentication method used [8]

younger users, who frequently cite insufficient information as a key reason for their reluctance to adopt passkeys. Many also mistake passkeys with other technologies like 2FA, which shows that the term passkeys doesn't precisely communicate what the technology entails [8].

Additionally, misconceptions about the security of passkeys hinder their acceptance. Some users, even those familiar with the technology, mistakenly believe that passkeys are less secure than traditional authentication methods [8]. This skepticism is often rooted in a lack of education on the cryptographic mechanisms. Such doubts are exacerbated by the insufficient communication from online service providers. While some platforms offer passkeys as an alternative login method, they don't inform their users enough about the technology and how it can increase security. Users frequently cite to perceive no clear recommendation from service providers for the adoption of passkeys [8]. Consequently, users perceive no clear advantage from adopting passkeys.

### Technical Barriers and Usability Concerns

For many users, especially those less familiar with technology or from older age groups, passkeys may appear overly complex or difficult to use. Unlike passwords, which are familiar and straightforward, the process of setting up passkeys can seem cumbersome [8]. For instance, users must understand how to link their devices, manage their credentials, and recover accounts if access is lost. This learning curve can discourage adoption, particularly among individuals accustomed to simpler, albeit less secure, methods of authentication.

Moreover, the integration of passkeys across multiple devices and platforms poses another challenge. Many users expect seamless access across shared or public devices, which isn't

currently easily achievable with passkey systems [5]. This limitation further diminishes their perceived convenience compared to passwords or other traditional authentication methods.

## **5.2 Companies**

The adoption of passkeys by companies is significantly influenced by various organizational, technical, and cultural factors. While passkeys offer a robust solution to many vulnerabilities associated with traditional authentication methods, their implementation within corporate environments faces several hurdles. These challenges stem from misconceptions about the technology, technical integration difficulties, and resistance to change within established workflows. Companies must weigh the benefits of enhanced security and reduced IT overhead against the costs and risks associated with transitioning to a new authentication system. Additionally, varying levels of technical infrastructure and regulatory compliance requirements complicate the widespread adoption of passkeys. This section explores the specific barriers companies encounter when considering passkey adoption, including technical challenges, mindset barriers, and the role of regulatory constraints.

### **Misconceptions**

Widespread misconceptions about passkeys and the underlying FIDO principles hinder the adoption. Some organizations mistakenly believe that FIDO relies on roaming authenticators like the YubiKey, requires centralized entities like public key infrastructures (PKI), or necessitates a dedicated app [7].

These misconceptions are further heightened by difficulties in explaining passkeys to non-technical stakeholders, including management and UX designers. Poorly designed interfaces resulting from inadequate understanding of passkey principles reduce usability and discourage adoption. Furthermore, the lack of clear, concise communication about the benefits and functionality of passkeys creates resistance to change within organizations [7].

### **Technical Challenges**

Another significant challenge lies in the technical implementation of passkeys, particularly in environments with diverse software ecosystems. The usability of passkeys across different platforms remains a technical difficulty [7]. Passkey ecosystems rely on the native support of platform vendors such as Google, Apple, and Microsoft for proper usage between devices and operating systems [5]. Transferring passkeys across ecosystems is possible thanks to solutions like the use of QR codes, yet these solutions remain confusing as well as error-prone. Commercial and open-source password managers are already deploying functionalities to manage passkeys, which would decouple the passkey management from any particular ecosystem. However, the vast majority of the population does not use password managers and resorts to built-in solutions [7]. Varying operating systems and browsers display FIDO interface elements inconsistently. This inconsistency makes it difficult for users to recognize passkeys as a unified login mechanism across devices and services. The

lack of support for passkeys in various browsers and Legacy software further complicates adoption. In most cases, companies depend on identity and access management (IAM) vendors to provide passkey solutions, since in-house implementations are rarely possible. However, the provided solutions may not be compatible with older systems. Additionally, fallback and account recovery mechanisms, while largely resolved with passkeys, remain inconsistently handled by different services, which leads to further confusion and a lack of trust [7].

### **Mindset and Opinions**

Many companies remain skeptical about the necessity of passkeys, often viewing them as redundant compared to existing secure solutions like risk-based authentication (RBA), two-factor authentication (2FA), and single sign-on (SSO). For some, passkeys are perceived solely as an enhanced password manager rather than an alternative authentication method. There is also a significant lack of trust in the ability of major tech companies like Apple and Google to securely store private keys. Concerns about cloud-based synchronization persist, with many organizations rightfully believing that the security of passkeys ultimately depends upon the strength of passwords protecting the associated cloud accounts themselves. Without a completely passwordless ecosystem, some argue that passkeys fail to deliver a meaningful security improvement [7]. Additionally, companies often place the responsibility for account security on their customers and therefore don't see the necessity of adopting a new authentication method despite the potential security benefits [7]. The chicken-and-egg dynamic—where adoption by users depends upon the support of passkeys by service providers and vice versa—also holds back progress[5].

### **Regulatory Requirements**

Compliance with regulatory requirements is crucial in many industries, particularly in sectors that deal with sensitive information, such as finance. Laws and internal policies are designed to ensure that systems are secure, privacy is protected, and users can trust the services they use. However, these regulations often introduce complexities that can hinder the adoption of new technologies like passkeys. Two regulatory frameworks to consider when discussing the challenges of passkey adoption are PSD2 and eIDAS, both of which are EU regulations related to secure online transactions and identification. PSD2 is a regulation in the EU designed to increase competition and innovation in the payments' industry, while also enhancing the security of online payments [3]. One key aspect of PSD2 is the requirement for strong customer authentication. This means that when a user conducts a transaction, they must authenticate their identity using at least two of the following methods:

1. Something the user knows (e.g. password or PIN),
2. Something the user has (e.g. mobile device or card),
3. Something the user is (e.g. biometrics).

This is called dynamic linking and ensures that the authentication process is specific to

both the transaction and the person performing it [7]. eIDAS is another EU regulation that governs electronic identification (eID) and trust services like electronic signatures [4]. One of the key principles of eIDAS is that a person's identity must be securely tied to a specific hardware device. This is especially relevant for high-security applications such as digital signatures, where users must prove their identity with a strong form of authentication tied to a physical device (e.g. smart card or hardware token). However, passkeys, which can synchronize across multiple devices, conflict with the eIDAS requirement that identification should be tied to a specific hardware device [7].

## **6 Discussion**

The shift from passwords to passkeys represents a crucial advancement in authentication, addressing long-standing vulnerabilities while promising a more user-friendly experience. However, this transformation involves navigating significant technical and societal challenges. Passkeys eliminate many security risks associated with passwords, such as phishing and brute force attacks, by utilizing public key cryptography. Despite these benefits, their adoption faces challenges, including unfamiliarity and usability concerns, particularly in the older population. Similarly, accessing accounts from foreign devices remains a challenge, highlighting the need for improvements that balance security with flexibility.

For organizations, integrating passkeys into diverse and often outdated systems is complex. Misconceptions about passkeys' reliance, coupled with inconsistent platform support and regulatory requirements, further complicate their implementation. Addressing these challenges requires a well-rounded approach. For individuals, cohesive interfaces, better educational outreach, and standardized recovery mechanisms can demystify passkeys and build trust. For organizations, aligning passkey systems with existing identity frameworks and promoting standardization across platforms will be critical. Regulatory clarity is equally important. Current requirements often conflict with the synchronization mechanisms central to passkeys. Aligning regulations with technological advancements can encourage widespread adoption, especially in high-security industries like finance.

The potential benefits of widespread passkey adoption extend beyond enhanced security. They promise to reduce the burden of password management and improve user experience. However, achieving these benefits depends on addressing awareness and misconceptions as well as current limitations to ensure the technology becomes accessible to a broad spectrum of users. Replacing passwords with passkeys doesn't appear to be a realistic goal in the near future. Established authentication methods are likely to remain the preferred choice for most users and will need to continue to be supported as fallbacks, especially in the absence of a standardized recovery process. However, passkeys have the potential to significantly increase adoption, particularly among security-conscious users.

## Literatur

- [1] FIDO Alliance. 2024. URL: <https://fidoalliance.org/passkeys/#resources> (besucht am 15. 12. 2024).
- [2] FIDO Alliance. 2024. URL: <https://fidoalliance.org/fido2/> (besucht am 15. 12. 2024).
- [3] European Central Bank. 2018. URL: [https://www.ecb.europa.eu/press/intro/miponline/2018/html/1803\\_revisedpsd.en.html](https://www.ecb.europa.eu/press/intro/miponline/2018/html/1803_revisedpsd.en.html) (besucht am 16. 01. 2025).
- [4] European Commission. 2024. URL: <https://digital-strategy.ec.europa.eu/en/policies/eidas-regulation> (besucht am 16. 01. 2025).
- [5] Dr. A. Shaji George. *The Dawn of Passkeys: Evaluating a Passwordless Future. Partners Universal Innovative Research Publication*. Partners Universal Innovative Research Publication, 2024. URL: <https://doi.org/10.5281/zenodo.10697886>.
- [6] Hanko.io. 2024. URL: <https://www.passkeys.io/technical-details> (besucht am 15. 12. 2024).
- [7] L. Lassak und more. *Why Aren't We Using Passkeys? Obstacles Companies Face Deploying FIDO2 Passwordless Authentication*. SecureComm, Springer, 2024.
- [8] D. Domke Y. Blunck. *Passwortloses Authentisierungsverfahren Passkeys: Quantitative und qualitative Online-Befragung von Verbraucherinnen und Verbrauchern (März – Mai 2024)*. Bonn: Bundesamt für Sicherheit in der Informationstechnik, 2024.